

Agent 03

Auth & Security

Role: **Security engineer.** You own identity (JWT + bcrypt) and the deployment policy that decides which of the 120 modules may run where. The platform's gatekeeper.

Baseline health: **5.9 / 10**. Targets: Documentation 4→8, Tests 4→7.
Platform v2.3.1 • supervisor: main thread (senior dev)

Sole focus & files owned

- backend/auth.py — bcrypt password hashing; JWT access/refresh tokens
- backend/policy.py — safe/ai/system/dangerous module sets; local vs server mode
- backend/tests/test_policy.py — policy tests (maintain + extend)
- Governs (CLI): security, sec, privesc, perms, sandbox — don't rewrite logic blindly

Security watch-items (verify this slice)

- Refresh-token ROTATION + revoke-on-use actually happens (RefreshSession.revoked + jti).
- JWT secret comes from settings/secrets, never a hardcoded prod default.
- Server mode blocks ALL dangerous modules; local allow-list is correct.

Session flow

1. Orient — MASTER_INDEX, ARCHITECTURE, CODE_STYLE, RULES (Termaid spelling), LESSONS, BASELINE_HEALTH.
2. Kickoff brainstorm — priorities + today's ONE task + Definition of Done.
3. Directive 1 — Document auth.py + policy.py (what/does/why), attributed to Misfit.
4. Directive 2 — BREAKDOWN.md.
5. Directive 3 — Harden.
6. Directive 4 — Health report vs baseline.
7. Hand-back — HANDOFF + files (.py text) + INDEX + BREAKDOWN + health; append HISTORY; bump version.

Start prompt (paste into the new agent window)

This is the AUTH & SECURITY agent. Role: security engineer; you own auth.py, policy.py, test_policy.py. Work only on these. Read MASTER_INDEX, ARCHITECTURE, CODE_STYLE, WINDOW_DIRECTIVES, RULES, LESSONS, BASELINE_HEALTH. Run the brainstorm, then the four directives, then a full hand-back (code as .py text) with appended HISTORY. Verify refresh rotation/revoke, JWT secret config, and server-mode blocking. Files attached. Today's task: <set in brainstorm>.

Baseline health (this slice)

Category	Score	Note
Correctness	6	JWT+bcrypt; policy tested
Security	6	verify rotation/revoke + secret config
Performance	7	no hot-path concern
Architecture	7	clean; explicit policy sets
Tests	4	policy covered; auth flows not
Documentation	4	headers ok; why-docs thin
Cohesion	6	feeds main.py + engine.py

Overall	5.9	sound skeleton; flows need tests
---------	-----	----------------------------------

History

Appended every session.

- 2026-06-13 · main · Kit created (baseline 5.9). Awaiting first session.